



# Bezpieczeństwo danych i systemów informatycznych

Wykład I



# **I. WPROWADZENIE**

# Bezpieczeństwo systemu komputerowego

- System komputerowy jest **bezpieczny**, jeśli jego użytkownik może na nim polegać, a zainstalowane oprogramowanie działa zgodnie ze swoją specyfikacją.

# Wiarygodność systemu

## System wiarygodny =

- dyspozycyjny (*available*) = dostępny na bieżąco
- niezawodny (*reliable*) = odporny na awarie
- bezpieczny (*secure*) = zapewniający ochronę danych
- bezpieczny (*safe*) = bezpieczny dla otoczenia, przyjazny dla środowiska

# Bezpieczeństwo SI jest ważne bo:

- Systemy informatyczne (SI) są niezbędne do funkcjonowania współczesnej cywilizacji
- Trudno jest zbudować SI bezpieczny i niezawodny
- Procedury bezpieczeństwa wiążą się zwykle z niewygodą użytkowników i kosztami

# Zagrożenia bezpieczeństwa

- **Celowe** (chęć zysku, uznania, zemsta) lub **przypadkowe** (nieświadomość użytkownika, zaniedbania, naiwność, wady sprzętu i oprogramowania)
- **Z zewnątrz systemu ()** lub **od środka** (użytkownicy autoryzowani do korzystania)

# Działania przeciw bezpieczeństwu komputerowemu

1. Włamanie do SI
2. Nieuprawnione pozyskanie informacji
3. Destrukcja danych lub systemów
4. Sabotaż SI (uniemożliwienie pracy)
5. Piractwo komputerowe, kradzież oprogramowania
6. Oszustwo komputerowe i fałszerstwo komputerowe
7. Szpiegostwo komputerowe

# Jurysdykcja w Polsce (m.in.)

- Artykuły 267-269 kk (Kodeksu Karnego)
- Artykuł 287 kk
- Ścigane zazwyczaj na wniosek pokrzywdzonego, a nie z oskarżenia publicznego

# Komponenty SI w kontekście bezpieczeństwa

- Stanowisko komputerowe
- Infrastruktura sieciowa
- System Operacyjny (SO) i usługi narzędziowe
- Aplikacje użytkowe



## **2. OGÓLNE ZASADY KONSTRUKCJI ZABEZPIECZEŃ**

# Nie istnieje bezpieczeństwo absolutne

- nie da się przewidzieć wszystkich możliwych zagrożeń
- zabezpieczać należy z wyprzedzeniem
- Szybki rozwój technologii powoduje powstawanie nowych zagrożeń i możliwości ataku

# Napastnik zazwyczaj nie pokonuje zabezpieczeń, ale ich unika

- Atak na aktywny mechanizm bezpieczeństwa zwykle jest czasochłonny i niebezpieczny (łatwy do wykrycia, pozostawia ślady)
- Tańsze i szybsze jest znalezienie luki w zabezpieczeniach
- Większość ataków przeprowadzanych jest „od środka” (przez autoryzowanych użytkowników systemu, którzy przekraczają swoje uprawnienia)

# Nie należy pokładać zaufania w jednej linii obrony

- Jedne (nawet najmocniejsze) zabezpieczenie może zostać ominięte czy dezaktywowane
- Powinno się konstruować wiele linii obrony (zabezpieczeń broniących tego samego aspektu SI)

# Złożoność jest wrogiem bezpieczeństwa

- Skomplikowane systemy są trudne do opanowania i analizy
- Modularna konstrukcja ułatwia kontrolę nad SI, również w aspekcie bezpieczeństwa

# Brak oznak ataku nie oznacza, że system jest bezpieczny

- Wykrycie ataku zwykle jest trudne
- Ewentualne oznaki ataku pojawiają się zwykle dopiero po jego zakończeniu, kiedy ponieśliśmy straty
  - np. dezaktywacja składników SI, utracone dane, utracona reputacja

# Mechanizmy bezpieczeństwa ograniczają wygodę użytkowników

- Użytkownicy zwykle nie są zainteresowani bezpieczeństwem, ale efektywnością i wygodą pracy
- Mechanizmy bezpieczeństwa stanowią tu przeszkodę (np. konieczność wielokrotnego wpisywania hasła, przeciągania identyfikatorem przy przechodzeniu przez drzwi, autoryzacji co ważniejszych transakcji, itp.)



### **3. STRATEGIA BEZPIECZEŃSTWA**

# Strategia bezpieczeństwa

## Określa:

1. **Co** chronić?
2. **Przed czym** chronić?
3. **Jakie koszty** opłaca się ponieść na ochronę?

# I. Co chronić?

1. Sprzęt komputerowy
2. Infrastruktura sieciowa
3. Wydruki
4. Dane o znaczeniu strategicznym
5. Kopie zapasowe
6. Wersje instalacyjne oprogramowania
7. Dane osobowe
8. Dane audytu
9. Zdrowie pracowników
10. Prywatność pracowników
11. Zdolności produkcyjne
12. Wizerunek publiczny i reputacja organizacji

## 2. Przed czym chronić?

1. Włamywacze komputerowi
2. Infekcje wirusami
3. Destruktywność pracowników oraz personelu zewnętrznego (np. firmy sprzątającej, kominiarza)
4. Błędy w programach
5. Kradzież dysków przenośnych, laptopów
6. Utrata łączy komunikacyjnych
7. Bankructwo producenta sprzętu lub firmy serwisowej
8. Choroba administratora, kierownika (jednoczesna choroba/nieobecność wielu osób)
9. Klęski żywiołowe (pożar, powódź, trzęsienie ziemi, trąby powietrzne)

### 3. Jakie koszty opłaca się ponieść na ochronę?

- Wdrażanie i używanie mechanizmów bezpieczeństwa wiąże się z kosztami
- Chronione zasoby posiadają swoją wartość (można je odtworzyć lub zastąpić ponosząc określone koszty)
- Wybór stosowanych mech. bezp. wymaga więc oszacowania ryzyka i analizy kosztów

# Polityka bezpieczeństwa

**Polityka bezpieczeństwa** – formalny dokument opisujący strategię bezpieczeństwa firmy

Etapy tworzenia:

1. Projektowanie
2. Implementacja
3. Zarządzanie, monitorowanie i konserwacja

# Zakres tematyczny polityki bezpieczeństwa (PB)

- Definicja celu i misji PB
- Wskazanie standardów i wytycznych, które są przestrzegane
- Wskazanie zadań do wykonania
- Przydzielenie zakresów odpowiedzialności (przyporządkowanie zadań określonym stanowiskom)

# Specyfikacja środków PB

- Ochrona fizyczna
- Polityka proceduralno-kadrowa
- Mechanizmy techniczne

# Normy i zalecenia zarządzania bezpieczeństwem

- Najważniejsza: ISO/IEC TR 13335 (ratyfikowana w Polsce jako PN-I-13335):
  - Terminologia i modele
  - Metodyka planowania i prowadzenia analizy ryzyka, specyfikacja wymagań stanowisk pracy
  - Techniki zarządzania bezpieczeństwem
  - Metodyka doboru zabezpieczeń
  - Zabezpieczanie połączeń z sieciami zewnętrznymi

... i wiele innych norm